INTERNAL OPERATIONS

Rebuy
Admin Manual

The cockpit, the tenants, the money —
and the things that must not break.

Platform operators only · Version 1.0 · November 2026

REBUY · RETENTION OS
Kampala, Uganda

Operating the Rebuy platform across every tenant

WHAT IS INSIDE

Contents

Eleven sections. Sections 3–7 are the daily work; 8–11 are the things that only bite once.

01 **What admins are**

Administrative accounts. No shop, no shop dashboard.

02 **The cockpit**

The nine screens and what each answers.

03 **Onboarding a tenant**

Retail shop, or healthcare provider.

04 **Supporting a shop**

Impersonation, and how to do it without looking careless.

05 **Credentials & channels**

WhatsApp, SMS, SMTP. Platform-wide and per shop.

06 **The queue & the worker**

What is stuck, and what to do at 2am.

07 **Audit log**

Every action, by whom, on which shop.

08 **Healthcare tenants**

Encryption, access logs, the clinical guard.

09 **Plans, revenue & capacity**

MRR, plan mix, and the 100-shop evidence.

10 **Runbook**

Deploy, rotate, restore, break-glass.

11 **Hard limits**

What this platform will not do.

> i **Scope of this document**
>
> This manual covers operating the platform. It assumes you can sign in as a platform admin and reach the cockpit at /admin.

SECTION 01

What admins are

An administrative account, not a super-shop.

Admins operate the platform. They do not sell, do not own stock, and **never get a shop of their own**. This is enforced, not merely conventional: signing in as an admin takes you straight to the cockpit, and there is no path from there into a shop dashboard except deliberate impersonation.

How an account becomes admin

The email address must appear in the **REBUY_ADMIN_EMAILS** environment variable, comma-separated. Sign in with Google using that address, or provision a password account, and the role is granted. Remove the address and the role goes with it on next sign-in.

> ! **Admin is powerful and quiet**
>
> An admin can read every tenant's data, change prices, reset any password and impersonate any user. Every one of those actions is written to the audit log with your email against it. Treat the log as the thing that keeps this honest.

SECTION 02

The cockpit

Nine screens, each answering one question.

Screen	The question it answers
Platform overview	How is the whole platform doing right now?
Shops	Who is on the platform, and what state are they in?
Messaging	Volume, delivery, failures and cost, by provider.
Retention engine	Do reminders actually bring customers back?
Revenue	MRR, plan mix, trial conversion.
Queue & worker	What is due, what is stuck, when the worker last ran.
Provider credentials	Platform-wide WhatsApp, SMS and SMTP settings.
Capacity	Evidence the platform carries 100+ shops.
Audit log	Every action, by whom, on which shop.

The cockpit is a separate document at **/admin** — not a hash route inside the shop app. If you find yourself in the shop shell as an admin, something is wrong; say so rather than working around it, because that symptom has historically meant a redirect bug.

SECTION 03

Onboarding a tenant

Two shapes: retail shop, or healthcare provider. Same table, different data.

Retail shop

1 **Create the shop**

Shops → New shop. Name, sector, city, currency, plan. The name appears on customer messages, so use the trading name.

2 **Create the owner login**

Either invite them by email, or issue a password directly with the demo-login endpoint (Section 10). Self-service signup works too if REBUY_ALLOW_SIGNUP is on.

3 **Add products with durations**

The tenant can do this themselves, but doing the first ten with them is the highest-value support you can give. Duration errors cause most early dissatisfaction.

4 **Connect a channel**

See Section 5. Without a channel, nothing sends.

5 **Import their customers**

Encourage a small first batch.

Healthcare provider (hospital, clinic, dental practice)

Same shop record, with **sector = Healthcare**, plus four things:

What	How
Branches	One account, many branches — each with its own client list, shared reporting. Created as places on the shop.
Services with recall intervals	The clinical equivalent of a product duration. Seed the common ones, then let them adjust.
Client records	Uploaded from their register (CSV/XLSX). Preview first, always.
A stable encryption key	REBUY_PRIVACY_KEY must be set before the first real record. See Section 8 — this is the one that cannot be undone.

✕ **Set the encryption key first**

If records are written before REBUY_PRIVACY_KEY is set, they are encrypted with the fallback secret. Changing it afterwards makes every existing client field unreadable — there is no recovery. Set it, verify it, then import.

SECTION 04

Supporting a shop

Impersonation is the sharpest tool here.

Impersonation signs you in as a shop user to see what they see. Use it when a description of a screen problem is not converging, and stop using it the moment it is.

Do	Do not
Reproduce the exact complaint as the user	Change settings, unless that is the fix they asked for
Leave within minutes	Read client records out of curiosity
Tell the shop afterwards if you changed anything	Impersonate without a support reason

Every impersonation is audited against your email and the shop. That record is the answer to “who looked at our data?” — which, for a healthcare tenant, someone will eventually ask.

SECTION 05

Credentials & channels

Platform-wide defaults, overridable per shop.

Resolution order for any message: **shop-level credential** → **platform credential** → **environment variable** → **sandbox**. If you reach sandbox, the message is written to the database and *nothing is sent*. Sandbox is a valid dev mode and a silent failure in production — know which one you are in.

Channel	Fields	Notes
WhatsApp (Meta)	token, phone_number_id, api_version, from_number	Template messages required outside the 24-hour window.
SMS (Twilio)	sid, auth_token, from_number	Sender ID registration is per-country.
Email (SMTP)	host, port, user, password, from_address, security	Without this, password-reset emails never arrive.

! **Test credentials, do not assume them**

Provider credentials → Test sends a real message to a number you supply. Do this after every change. A wrong token fails silently at send time and looks like a customer who did not reply.

SECTION 06

The queue & the worker

When reminders stop moving, start here.

The worker drains the queue. On Vercel it is driven by a cron hit to **/api/cron/tick**; REBUY_WORKER=0 disables the in-process worker.

Symptom	Check first
Nothing sends at all	Worker last-run time in Queue & worker. If stale, the cron is not firing.
Messages stuck in queued	Approval mode on that shop, or a credential that fails at send.
High failure rate on one provider	Provider status, then the credential test.
Duplicates	Two products, or a re-import. Check the audit log before assuming a bug.

POST /api/admin/tick forces a drain. It is safe to run more than once. Use it when you need to prove to a tenant that their reminders are queued and correct, without waiting for the next cron.

SECTION 07

Audit log

The platform's memory, and your alibi.

Every privileged action writes a row: actor email, action, shop, target, timestamp. When a tenant asks “who looked at this record”, when a message goes out that should not have, and when two operators disagree about what happened, this is the answer.

Practical habits

Habit	Why
Search by shop before a support call	You often find the answer already in the log.
Search by actor when investigating a change	Distinguishes a bug from an action someone took.
Export nothing by default	Bulk reads are recorded as disclosures, deliberately.

SECTION 08

Healthcare tenants

The rules that carry real-world consequences.

A healthcare tenant holds other people's medical information. Four mechanisms protect it, and all four must be working before a real patient record is loaded.

Mechanism	What it does	Where to verify
Field encryption	dob, file number, condition, address, notes encrypted at rest with Fernet.	Privacy status on the care overview; or read a raw row and look for enc:v1:
Access log	Every client read recorded before data is returned: actor, action, ip, user agent.	client records → each open writes an access_log row
Clinical guard	Blocks any outbound message containing a diagnosis or a test result. Held, not sent, logged to message_audit.	Test with a body containing a clinical term before go-live
Bulk disclosure marking	CSV export recorded as a bulk disclosure.	Care privacy endpoint

Demonstrating it works

Two checks worth running whenever you deploy anything touching the care layer:

```
1. Read a raw row directly from the database.
   Expect: dob and identifier start with  enc:v1:

2. Open the same record through the app as the tenant.
   Expect: readable date and file number, and a new access_log row.

If step 2 shows  [encrypted — could not be opened with this key]
the running deployment does not have the key that encrypted the row.
```

✕ The one unrecoverable mistake

REBUY_PRIVACY_KEY must never change once records exist. Rotating it makes every encrypted client field on every tenant permanently unreadable. Before the first real record: set it, deploy, verify. After that: treat it as immutable and store a copy in a safe place.

SECTION 09

Plans, revenue & capacity

The commercial view of the same platform.

Plan	Monthly	Customers	Messages / month
Starter	UGX 49,000	500	2,000
Growth	UGX 129,000	3,000	15,000
Scale	UGX 299,000	20,000	100,000

Revenue shows MRR, plan mix and trial conversion. **Capacity** is the evidence screen: it exists so that “can this carry a hundred shops?” is answered with numbers rather than assurances. Check it before promising a large tenant a launch date.

SECTION 10

Runbook

The operations you will need under pressure.

Deploy

```
git push origin main

vercel create_deployment  target=production

curl -s https://<host>/api/health   # ok:true, warnings:[]

curl -s -o /dev/null -w '%{http_code}' https://<host>/api/care/overview
                                    # 401 = route live, 404 = not deployed
```

A deploy can silently not happen — a deduplicated call, a queued build. Always confirm the new route or behaviour exists before telling anyone it shipped.

Issue or rotate a tenant's login

```
POST /api/admin/shops/<sid>/demo-login

Body: {"email": "owner@example.com", "password": "<optional>"}

Omitting password generates one and returns it once.

Existing sessions for that user are killed.
```

Use this whenever self-service reset is not reliable. Without SMTP configured, the “forgot password” link is written to the sandbox and never delivered — the account would otherwise be unrecoverable.

Rotate a secret

Secret	Rotating it costs you
REBUY_SECRET_KEY	All sessions signed out. Nobody loses data. Safe.
REBUY_PRIVACY_KEY	Every encrypted health field becomes unreadable. Never do this casually.
Provider tokens	Messages fail until the new token is tested. Rotate one channel at a time.
REBUY_DATABASE_URL	Total outage if wrong. Change, deploy, immediately verify /api/health.

Break-glass: locked out of the cockpit

Admin access comes from **REBUY_ADMIN_EMAILS**. If you are locked out, edit that variable in Vercel and redeploy — the role follows the address, so there is no separate password to recover. Confirm afterwards that the value contains the addresses you expect and no others.

SECTION 11

Hard limits

What this platform deliberately will not do.

Limit	Why it exists
No clinical content in messages	A reminder is not a channel for results. Blocked at the send choke point.
No unencrypted health fields in production	The privacy layer reports its mode; a build without the dependency runs in plaintext mode and says so loudly.
No bulk export without a log entry	Reading everything is an event worth recording.
Admins never hold a shop	Administrative and trading roles do not mix.
Imports are size-capped	Under 10,000 records per file by design; larger loads need a different mechanism.

> i **If a tenant asks for something on this list**
>
> The answer is usually “not this way”, not “no”. The clinical guard exists because the alternative is a diagnosis on a shared phone. Offer the safer wording instead of removing the guard.

End of the Rebuy Platform Admin Manual.